Static Application Security Testing report

Semgrep scan of the Entra ID Posture Scanner

Tool	Semgrep 1.182.1 (open-source CLI, offline, metrics off)
Date	2026-10-24
Target	Entire repository: application, tests, tools, docs, CI workflows, launchers
Rule sources	Official semgrep-rules repository (github.com/semgrep/semgrep-rules): python, javascript, generic, yaml, bash
Scope proof	70 files scanned, 7,371 lines; 0 files skipped by semgrep
Engine summary	Scanning 70 files tracked by git with 966 Code rules
Findings	94 total (ERROR 12, WARNING 81, INFO 1); scan errors: 0

Result

94 finding(s) reported; each is triaged below. Errors during the scan: none.

Files by type

(none)	5
.TAG	1
.bat	1
.js	1
.md	10
.ps1	1
.py	46
.txt	2
.yml	3

Findings and triage

Severity	Rule	Location	Disposition
WARNING	changed-semgrepignore - `__pycache__/` has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.	.semgrepignore:2	INFORMATIONAL - the project .semgrepignore overrides semgrep's default (which would skip tests/). It excludes only generated scan outputs (docs/security, docs/screenshots) and __pycache__.
WARNING	changed-semgrepignore - `docs/security/` has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.	.semgrepignore:3	INFORMATIONAL - the project .semgrepignore overrides semgrep's default (which would skip tests/). It excludes only generated scan outputs (docs/security, docs/screenshots) and __pycache__.
WARNING	changed-semgrepignore - `docs/screenshots/` has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.	.semgrepignore:4	INFORMATIONAL - the project .semgrepignore overrides semgrep's default (which would skip tests/). It excludes only generated scan outputs (docs/security, docs/screenshots) and __pycache__.

Severity	Rule	Location	Disposition
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	entra_scan/checks/authn.py:67	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	entra_scan/checks/conditional_access.py:151	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	entra_scan/checks/conditional_access.py:156	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	entra_scan/checks/tenant.py:103	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
ERROR	use-defused-xml - The Python documentation recommends using `defusedxml` instead of `xml` because the native Python `xml` library is vulnerable to XML External Entity (XXE) attac	entra_scan/export.py:9	ACCEPTED - entra_scan/export.py imports ElementTree only to BUILD the JUnit document from our own data (ET.tostring escapes all text and attributes); nothing untrusted is ever parsed with it, so the XML-parsing attacks defusedxml defends against (entity expansion, XXE) do not apply. Test code imports it to parse our own output. A fuzz/unit test (test_junit_is_well_formed_and_escapes_hostile_names) proves hostile names stay inert.
WARNING	return-not-in-function - `return` only makes sense inside a function	entra_scan/permissions.py:81	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	entra_scan/report.py:129	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
WARNING	contains-bidirectional-characters - This code contains bidirectional (bidi) characters. While this is useful for support of right-to-left languages such as Arabic or Hebrew, it can also be used to	tests/fuzz.py:27	ACCEPTED (test code only) - tests/fuzz.py deliberately contains a right-to-left override string as a hostile-input payload to prove reports render it as inert text.
WARNING	contains-bidirectional-characters - This code contains bidirectional (bidi) characters. While this is useful for support of right-to-left languages such as Arabic or Hebrew, it can also be used to	tests/fuzz.py:27	ACCEPTED (test code only) - tests/fuzz.py deliberately contains a right-to-left override string as a hostile-input payload to prove reports render it as inert text.
WARNING	unknown-value-with-script-tag - Cannot determine what 'html' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'html' is not externally c	tests/report_dom_shim.js:43	FALSE POSITIVE (test code only) - Node test shim reads our own generated report HTML to run the filter script; it is not browser code.

Severity	Rule	Location	Disposition
WARNING	unknown-value-with-script-tag - Cannot determine what 'html' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'html' is not externally c	tests/report_dom_shim.js:43	FALSE POSITIVE (test code only) - Node test shim reads our own generated report HTML to run the filter script; it is not browser code.
WARNING	unknown-value-with-script-tag - Cannot determine what 'html' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'html' is not externally c	tests/report_dom_shim.js:43	FALSE POSITIVE (test code only) - Node test shim reads our own generated report HTML to run the filter script; it is not browser code.
WARNING	unknown-value-with-script-tag - Cannot determine what 'html' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'html' is not externally c	tests/report_dom_shim.js:43	FALSE POSITIVE (test code only) - Node test shim reads our own generated report HTML to run the filter script; it is not browser code.
WARNING	eval-detected - Detected the use of eval(). eval() can be dangerous if used to evaluate dynamic content. If this content can be input from outside the program, this may be a co	tests/report_dom_shim.js:44	ACCEPTED (test code only) - the Node shim evaluates the report's own filter script (generated by this project) under a fake DOM to unit-test filtering.
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:109	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:111	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:113	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:115	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:117	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:119	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:121	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).

Severity	Rule	Location	Disposition
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:123	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:131	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:133	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:152	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:154	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:156	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:160	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:161	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:162	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:163	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).

Severity	Rule	Location	Disposition
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:165	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:169	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:170	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:171	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:176	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:176	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:179	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:179	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:180	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:181	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).

Severity	Rule	Location	Disposition
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:182	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:184	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:186	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:190	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:191	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:192	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:195	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:198	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:201	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:202	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).

Severity	Rule	Location	Disposition
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:203	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:204	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:205	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:206	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:207	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:208	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:209	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:210	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:211	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:213	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).

Severity	Rule	Location	Disposition
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:214	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:215	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:216	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/test_checks.py:217	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
ERROR	use-defused-xml - The Python documentation recommends using `defusedxml` instead of `xml` because the native Python `xml` library is vulnerable to XML External Entity (XXE) attac	tests/test_features.py:4	ACCEPTED - entra_scan/export.py imports ElementTree only to BUILD the JUnit document from our own data (ET.tostring escapes all text and attributes); nothing untrusted is ever parsed with it, so the XML-parsing attacks defusedxml defends against (entity expansion, XXE) do not apply. Test code imports it to parse our own output. A fuzz/unit test (test_junit_is_well_formed_and_escapes_hostile_names) proves hostile names stay inert.
ERROR	dangerous-subprocess-use-audit - Detected subprocess function 'run' without a static string. If this data can be controlled by a malicious actor, it may be an instance of command injection. Aud	tests/test_misc.py:70	ACCEPTED (test code only) - tests launch this project's own CLI/tools with fixed argument lists, shell=False, no tenant or user data in the command.
ERROR	dangerous-subprocess-use-audit - Detected subprocess function 'run' without a static string. If this data can be controlled by a malicious actor, it may be an instance of command injection. Aud	tests/uat.py:107	ACCEPTED (test code only) - tests launch this project's own CLI/tools with fixed argument lists, shell=False, no tenant or user data in the command.
ERROR	dangerous-subprocess-use-audit - Detected subprocess function 'run' without a static string. If this data can be controlled by a malicious actor, it may be an instance of command injection. Aud	tests/uat.py:115	ACCEPTED (test code only) - tests launch this project's own CLI/tools with fixed argument lists, shell=False, no tenant or user data in the command.
ERROR	dangerous-subprocess-use-audit - Detected subprocess function 'run' without a static string. If this data can be controlled by a malicious actor, it may be an instance of command injection. Aud	tests/uat.py:121	ACCEPTED (test code only) - tests launch this project's own CLI/tools with fixed argument lists, shell=False, no tenant or user data in the command.
ERROR	dangerous-subprocess-use-audit - Detected subprocess function 'run' without a static string. If this data can be controlled by a malicious actor, it may be an instance of command injection. Aud	tests/uat.py:129	ACCEPTED (test code only) - tests launch this project's own CLI/tools with fixed argument lists, shell=False, no tenant or user data in the command.

Severity	Rule	Location	Disposition
ERROR	use-defused-xml - The Python documentation recommends using `defusedxml` instead of `xml` because the native Python `xml` library is vulnerable to XML External Entity (XXE) attac	tests/uat.py:194	ACCEPTED - entra_scan/export.py imports ElementTree only to BUILD the JUnit document from our own data (ET.tostring escapes all text and attributes); nothing untrusted is ever parsed with it, so the XML-parsing attacks defusedxml defends against (entity expansion, XXE) do not apply. Test code imports it to parse our own output. A fuzz/unit test (test_junit_is_well_formed_and_escapes_hostile_names) proves hostile names stay inert.
WARNING	unspecified-open-encoding - Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-p	tests/uat.py:257	ACCEPTED (test code only) - UAT script opens its own JSON output; ASCII/UTF-8 only.
ERROR	use-defused-xml-parse - The native Python `xml` library is vulnerable to XML External Entity (XXE) attacks. These attacks can leak confidential data and "XML bombs" can cause denial o	tests/uat.py:258	ACCEPTED (test/UAT code only) - tests/uat.py parses the JUnit file this tool just wrote itself, to check it is well-formed.
ERROR	dangerous-subprocess-use-audit - Detected subprocess function 'run' without a static string. If this data can be controlled by a malicious actor, it may be an instance of command injection. Aud	tests/uat.py:325	ACCEPTED (test code only) - tests launch this project's own CLI/tools with fixed argument lists, shell=False, no tenant or user data in the command.
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/uat.py:364	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	tests/uat.py:366	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
ERROR	dangerous-subprocess-use-audit - Detected subprocess function 'run' without a static string. If this data can be controlled by a malicious actor, it may be an instance of command injection. Aud	tests/uat_browser.py:10	ACCEPTED (test code only) - tests launch this project's own CLI/tools with fixed argument lists, shell=False, no tenant or user data in the command.
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/uat_browser.py:27	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tests/uat_browser.py:33	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
ERROR	arbitrary-sleep - time.sleep() call; did you mean to leave this in?	tests/uat_gui.py:38	ACCEPTED (test code only) - tests/uat_gui.py waits for the Tk event loop in a polling loop with a bounded timeout; no production code sleeps this way.

Severity	Rule	Location	Disposition
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	tools/gen_docs.py:25	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	tools/gen_docs.py:47	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	tools/gen_docs.py:56	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
WARNING	return-not-in-function - `return` only makes sense inside a function	tools/make_sample_report.py:12	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tools/sast.py:99	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tools/sast.py:103	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tools/semgrep_pdf.py:21	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	return-not-in-function - `return` only makes sense inside a function	tools/semgrep_pdf.py:22	FALSE POSITIVE - the rule mis-reads Python lambda expressions as a bare return; no return statement exists outside a function (verified; interpreter would raise SyntaxError).
WARNING	string-concat-in-list - Detected strings that are implicitly concatenated inside a list. Python will implicitly concatenate strings when not explicitly delimited. Was this supposed to	tools/semgrep_pdf.py:73	ACCEPTED - intentional line-wrapped string literals (long help/finding text). No missing commas: every affected line is exercised by the test suite.
INFO	private-key - A gitleaks private-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks	tools/setup_app_registration.ps1:99	FALSE POSITIVE - tools/setup_app_registration.ps1 contains only the literal PEM header/footer text used to wrap a key the script generates at run time; no key material is stored in the repository.

Appendix A - files scanned (proof of coverage)

.github/workflows/ci.yml | .github/workflows/trufflehog.yml | .github/workflows/zap.yml | .gitignore | .pytest_cache/.gitignore | .pytest_cache/CACHEDIR.TAG | .pytest_cache/README.md | .pytest_cache/v/cache/lastfailed | .pytest_cache/v/cache/nodeids | .semgrepignore | CHANGELOG.md | LIVE_VALIDATION.md | README.md | SECURITY.md | build_exe.bat | constraints.txt | docs/CIS_COVERAGE.md | docs/PERMISSIONS.md | docs/TROUBLESHOOTING.md | docs/UAT.md | docs/UAT_REVIEW.md | entra_posture_gui.py | entra_posture_scan.py | entra_scan/__init__.py | entra_scan/auth.py | entra_scan/batch.py | entra_scan/checks/__init__.py | entra_scan/checks/apps.py | entra_scan/checks/authn.py | entra_scan/checks/conditional_access.py | entra_scan/checks/devices.py | entra_scan/checks/extended.py | entra_scan/checks/governance.py | entra_scan/checks/groups.py | entra_scan/checks/identity_protection.py | entra_scan/checks/manual.py | entra_scan/checks/privileged.py | entra_scan/checks/tenant.py | entra_scan/checks/users.py | entra_scan/cli.py | entra_scan/clouds.py | entra_scan/context.py | entra_scan/export.py | entra_scan/graph.py | entra_scan/gui.py | entra_scan/metadata.py | entra_scan/models.py | entra_scan/permissions.py | entra_scan/postprocess.py | entra_scan/report.py | entra_scan/runner.py | requirements.txt | tests/conftest.py | tests/fake_tenant.py | tests/fuzz.py | tests/report_dom_shim.js | tests/test_checks.py | tests/test_features.py | tests/test_misc.py | tests/test_postprocess.py | tests/uat.py | tests/uat_browser.py | tests/uat_gui.py | tools/check_links.py | tools/gen_docs.py | tools/make_sample_report.py | tools/sast.py | tools/secret_scan.py | tools/semgrep_pdf.py | tools/setup_app_registration.ps1

Appendix C - scan log (tail)

```
be interpreted as '/.github/workflows' to comply with the Semgrepignore v2 and Gitignore specifications. To make this
pattern permanently unanchored, edit rule
home.claude.sast.semgrep-rules.yaml.github-actions.security.audit.third-party-action-not-pinned-to-commit-sha and
change it to '**/.github/workflows'. To confirm the anchored behavior and avoid this warning, change it to
'/.github/workflows'.


■■■■■■■■■■■■■■■■
■ Scan Status ■
■■■■■■■■■■■■■■■■
Scanning 70 files tracked by git with 966 Code rules:

Language Rules Files Origin Rules
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■ ■■■■■■■■■■■■■■■■■
<multilang> 233 70 Custom 966
python 370 46
yaml 94 3
js 171 1

Rule home.claude.sast.semgrep-rules.yaml.github-actions.security.audit.third-party-action-not-pinned-to-commit-sha
contains an include pattern '.github/workflows' that will soon be interpreted as '/.github/workflows' to comply with
the Semgrepignore v2 and Gitignore specifications. To make this pattern permanently unanchored, edit rule
home.claude.sast.semgrep-rules.yaml.github-actions.security.audit.third-party-action-not-pinned-to-commit-sha and
change it to '**/.github/workflows'. To confirm the anchored behavior and avoid this warning, change it to
'/.github/workflows'.


■■■■■■■■■■■■■■■■■
■ Scan Summary ■
■■■■■■■■■■■■■■■■■
■ Scan completed successfully.
• Findings: 94 (94 blocking)
• Rules run: 866
• Targets scanned: 70
• Parsed lines: ~100.0%
• Scan skipped:
■ Files matching .semgrepignore patterns: 12
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 866 rules on 70 files: 94 findings.
exit 0
```

Reproduce: git clone https://github.com/semgrep/semgrep-rules; semgrep scan --metrics=off --config semgrep-rules/python --config semgrep-rules/generic --config semgrep-rules/javascript --config semgrep-rules/yaml --config semgrep-rules/bash --json -o semgrep.json .